Laporan Vulnerability Assessment - OJS

LAPORAN VULNERABILITY ASSESSMENT
Open Journal Systems (OJS)

Field	Nilai
Nama Tim	Kelompok 3
Anggota Tim	Joshua Washington Hutasoit; Brahmantio Jati Pambudi; Malvinshah Haris Athala; Steven Anthony; Darvesh Aziz Mawla; Sandhika Rizqi Ramadhan; Rhesa Tsaqif Adyatma; Mohamad Robi Alwan
Kelas	DevSecOps-A
Tanggal Pengujian	23 Maret 2026 - 08 April 2026
Tanggal Laporan	09 April 2026
Versi OJS Diuji	OJS 3.3.0-8
URL Target	`http://10.34.100.180/`
Status Laporan	Final

Daftar Isi

1. Executive Summary
2. Metodologi
3. Lingkungan Pengujian

4. Temuan - Detail
5. Risk Register & Summary
6. Rekomendasi Mitigasi
7. Patch Verification
8. Kesimpulan
9. Lampiran

---

1. Executive Summary

Kelompok 3 melaksanakan vulnerability assessment terhadap instance Open Journal Systems (OJS) versi 3.3.0-8 yang berjalan pada `http://10.34.100.180/` sebagai bagian dari studi kasus mata kuliah DevSecOps. Pengujian dilakukan berdasarkan dokumen scope dan Rules of Engagement pada pertemuan 1, kemudian dilanjutkan dengan attack surface mapping, pengujian DAST, pengujian SAST, manual code review, analisis OWASP/CVSS, serta finalisasi risk register. Tujuan utamanya adalah mengidentifikasi kelemahan yang dapat memengaruhi kerahasiaan data jurnal, integritas proses editorial, dan ketersediaan layanan.

Dari total 20 temuan final, 5 dikategorikan Critical, 5 High, 6 Medium, dan 4 Low. Temuan paling berisiko tidak hanya berasal dari konfigurasi runtime, tetapi juga dari pola source code yang dapat berkembang menjadi code execution, file abuse, dan persistent client-side attack. Secara umum, posture keamanan OJS pada lingkungan uji ini belum memadai untuk operasional produksi tanpa tindakan mitigasi tambahan karena terdapat kombinasi komponen usang, hardening yang belum lengkap, dan pola kode berbahaya.

Tiga risiko bisnis utama yang perlu diprioritaskan adalah: pertama, kompromi server melalui komponen middleware yang usang seperti Apache dan OpenSSH; kedua, eksekusi kode atau manipulasi alur aplikasi akibat penggunaan `eval()`, `assert()`, dan `unserialize()` yang tidak aman; ketiga, pengambilalihan sesi atau penyisipan skrip persisten melalui stored XSS pada `customHeaders`. Dalam 72 jam pertama, tindakan yang paling direkomendasikan adalah memperbarui komponen yang terdampak advisory keamanan, menonaktifkan jalur instalasi atau plugin yang tidak diperlukan di production, serta menerapkan hardening HTTP security headers dan kontrol file operation.

Total Temuan:

Severity	Jumlah
Critical	5
High	5
Medium	6
Low	4
Informational	0
Total	20

Risiko Bisnis Utama

1. Kompromi host dan layanan jurnal melalui Apache `2.4.58` dan OpenSSH `9.6p1` yang terpetakan ke beberapa CVE publik.
2. Code execution dan manipulasi file internal akibat penggunaan `eval()`, `assert()` dinamis, `unserialize()` tanpa pembatasan kelas, serta operasi file berbasis parameter dinamis.
3. Pengambilalihan sesi dan penyalahgunaan hak akses melalui stored XSS pada `customHeaders`, diperparah dengan tidak adanya CSP dan header keamanan yang belum lengkap.

Rekomendasi Segera

1. Upgrade seluruh komponen yang terdampak advisory keamanan ke rilis vendor-supported yang sudah patched, dengan prioritas Apache HTTP Server, OpenSSH, dan OJS.
2. Nonaktifkan installer, plugin upload via web, dan jalur yang tidak diperlukan pada lingkungan production sampai kontrol validasi serta integritas diverifikasi.
3. Terapkan baseline hardening web server: HTTPS, HSTS, CSP, `X-Frame-Options` atau `frame-ancestors`, `X-Content-Type-Options`, `Referrer-Policy`, serta `Options -Indexes`.

---

2. Metodologi

2.1 Pendekatan Pengujian

Pengujian menggunakan pendekatan hybrid black-box, grey-box, dan white-box:

- Black-box digunakan saat fingerprinting, port scanning, crawling, dan DAST terhadap instance yang berjalan pada `10.34.100.180`.
- Grey-box digunakan saat attack surface mapping serta interpretasi hasil tool dengan memanfaatkan konteks OJS 3.3.0-8 dan artefak dari pertemuan sebelumnya.
- White-box terbatas digunakan untuk SAST dan manual code review terhadap source code OJS 3.3.0-8 pada lingkungan analisis.

2.2 Scope dan Batasan

Scope utama:

- Instance OJS `3.3.0-8` pada `http://10.34.100.180/`
- Port publik yang terdeteksi terbuka: `22/tcp` dan `80/tcp`
- Route publik yang terobservasi: homepage, login, reset password, register, about page, asset delivery, dan sebagian API
- Source code OJS `3.3.0-8` untuk SAST dan manual review

Batasan pengujian:

- Tidak dilakukan exploit destruktif, DoS, atau perubahan permanen pada server target.
- SQLMap tidak menemukan injeksi SQL yang tervalidasi pada skenario uji yang dijalankan.
- Beberapa finding SAST merupakan hotspot yang diprioritaskan dengan internal risk alignment agar konsisten dengan risk register final.

2.3 Tahapan Pengujian

Fase	Aktivitas	Pertemuan	Tanggal
Reconnaissance	Fingerprinting, enumeration	2	23/03/2026
Attack Surface Mapping	Identifikasi entry point, data flow	2	23/03/2026
DAST	Nikto, ZAP, Nmap, SQLMap	3	02/04/2026
SAST	Semgrep, phpcs-security-audit, manual code review	3	02/04/2026 - 03/04/2026
Analisis & Scoring	OWASP mapping, CVSS, risk register	4	08/04/2026
Pelaporan	Penulisan laporan, rekomendasi	5	09/04/2026

2.4 Tools yang Digunakan

Kategori	Tool	Versi
DAST	OWASP ZAP	2.16.1
DAST	Nikto	2.6.0
DAST	SQLMap	1.10.2
DAST	Nmap	7.98
SAST	Semgrep	Tidak terdokumentasi
SAST	phpcs-security-audit	Tidak terdokumentasi
Recon	WhatWeb	Tidak terdokumentasi
Recon	Gobuster	Tidak terdokumentasi

Manual	Code Review	N/A

2.5 Artefak Bukti yang Dirujuk

- `../Deliverable Pertemuan 2/01-attack-surface.md`
- `../Deliverable Pertemuan 3/02-scanning-result.md`
- `../Deliverable Pertemuan 3/Raw-Finding-Table.md`
- `../Deliverable Pertemuan 3/manual_code_review.md`
- `../Deliverable Pertemuan 3/Nikto/raw_output_nikto.txt`
- `../Deliverable Pertemuan 3/Nmap/nmap_vuln.txt`
- `../Deliverable Pertemuan 3/Zap/raw_output_zap.html`
- `../Deliverable Pertemuan 3/Phpcs/phpcs_security_output.txt`
- `../Deliverable Pertemuan 3/Semgrep/semgrep_custom_results.json`
- `../Deliverable Pertemuan 3/Semgrep/semgrep_php_results.json`
- `../Deliverable Pertemuan 3/Semgrep/semgrep_owasp_results.json`
- `../Deliverable Pertemuan 4/OWASP-Top-10-Mapping.md`
- `../Deliverable Pertemuan 4/CVSS-Score-Calculation.md`
- `../Deliverable Pertemuan 5/Risk-Register-Final.md`

---

3. Lingkungan Pengujian

Komponen	Detail
Target OS	Ubuntu 22.04 LTS
Web Server	Apache 2.4.58
SSH Service	OpenSSH 9.6p1 Ubuntu 3ubuntu13.15
PHP Version	7.4.x
Database	MySQL 8.0
OJS Version	3.3.0-8
URL Target	`http://10.34.100.180/`
Port Terbuka	`22/tcp`, `80/tcp`

Port Tertutup yang Dicek	`443/tcp`, `8080/tcp`
Kondisi Aplikasi Saat Observasi	Homepage OJS aktif, tetapi belum ada jurnal publik yang ditayangkan
Session Cookie	`OJSSID` dibuat bahkan untuk akses anonim

---

4. Temuan - Detail

Catatan: untuk finding non-CVE atau hasil SAST/manual review, nilai CVSS pada section ini menggunakan internal risk alignment agar konsisten dengan risk register final pertemuan 5.

[VUL-001] Apache HTTP Server RCE (CVE-2024-38476)

Field	Nilai
ID	VUL-001
Nama	Apache HTTP Server RCE (CVE-2024-38476)
OWASP Category	A06:2021 - Vulnerable and Outdated Components
CWE	CWE-1395
CVE	CVE-2024-38476
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
CVSS Base Score	9.8 (Critical)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: Apache `2.4.58` pada port `80/tcp` dipetakan Nmap ke beberapa CVE publik, termasuk `CVE-2024-38476`, sehingga middleware inti yang melayani OJS berada pada kondisi rentan.

Dampak Bisnis: Bila web server dieksploitasi, attacker dapat memperoleh foothold pada host, memodifikasi konten jurnal, mencuri konfigurasi OJS, atau menghentikan layanan.

Langkah Reproduksi:

1. Jalankan Nmap service detection dan skrip kerentanan ke host target.
2. Verifikasi banner service HTTP yang aktif.
3. Cocokkan versi service dengan CVE yang dilaporkan skrip `vulners`.

Payload / Request:

```
nmap -sV --script vuln 10.34.100.180
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan Nmap.png`
- `../Deliverable Pertemuan 3/Nmap/nmap_vuln.txt`

Response / Output:

```
80/tcp open  http    Apache httpd 2.4.58 ((Ubuntu))
CVE-2024-38476  9.8
```

Rekomendasi:

- Jangka Pendek: Upgrade Apache HTTP Server ke rilis vendor-supported yang sudah patched dan pasang WAF sebagai kontrol sementara.
- Jangka Menengah: Terapkan baseline hardening Apache seperti `ServerTokens Prod`, `ServerSignature Off`, dan review modul aktif.
- Jangka Panjang: Masukkan scanning host dan patch management middleware ke proses operasi rutin.

[VUL-002] OpenSSH RegreSSHion (CVE-2024-6387)

Field	Nilai
ID	VUL-002
Nama	OpenSSH RegreSSHion (CVE-2024-6387)
OWASP Category	A06:2021 - Vulnerable and Outdated Components
CWE	CWE-362
CVE	CVE-2024-6387
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H`
CVSS Base Score	8.1 (High)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: Port `22/tcp` teridentifikasi menjalankan OpenSSH `9.6p1 Ubuntu 3ubuntu13.15` dan dipetakan ke `CVE-2024-6387`. Temuan ini berada di perimeter host yang sama dengan aplikasi OJS.

Dampak Bisnis: Eksploitasi pada service SSH dapat menyebabkan akses tidak sah ke host dan melewati seluruh kontrol keamanan di level aplikasi.

Langkah Reproduksi:

1. Jalankan Nmap service detection dan `--script vuln` ke host target.
2. Verifikasi banner service SSH yang aktif.
3. Cocokkan versi dengan CVE yang dilaporkan output Nmap.

Payload / Request:

```
nmap -sV --script vuln 10.34.100.180
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan Nmap.png`
- `../Deliverable Pertemuan 3/Nmap/nmap_vuln.txt`

Response / Output:

```
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.15
CVE-2024-6387  8.1
```

Rekomendasi:

- Jangka Pendek: Batasi akses SSH dengan allowlist IP, VPN, atau security group.
- Jangka Menengah: Upgrade OpenSSH ke rilis vendor-supported yang sudah patched dan aktifkan fail2ban.
- Jangka Panjang: Pisahkan akses administrasi host dari network exposure publik dan terapkan host hardening berkala.

[VUL-003] Eval Injection Pattern (Installer)

Field	Nilai
ID	VUL-003
Nama	Eval Injection Pattern (Installer)
OWASP Category	A03:2021 - Injection
CWE	CWE-94
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
CVSS Base Score	9.8 (Critical)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim SAST Kelompok 3

Deskripsi: Semgrep custom rule `php-eval-injection` menemukan penggunaan `eval()` berbasis variabel pada `Installer.inc.php`, termasuk line 383 dan 431. Sink ini berisiko sangat tinggi karena mengubah data menjadi kode PHP yang dieksekusi.

Dampak Bisnis: Jika jalur ini dapat dijangkau atau nilainya dapat dimanipulasi, attacker berpotensi menjalankan kode arbitrer dan mengompromikan aplikasi sepenuhnya.

Langkah Reproduksi:

1. Jalankan Semgrep custom rules pada codebase OJS.
2. Cari rule `php-eval-injection`.
3. Verifikasi hasil pada `Installer.inc.php`.

Payload / Request:

```
semgrep --config custom_rules.yaml --output semgrep_custom.json --json ./ojs-src
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Semgrep/semgrep_custom_results.json`
- `../Deliverable Pertemuan 3/Raw-Finding-Table.md`

Response / Output:

```
check_id: php-eval-injection
path: /var/www/html/ojs/lib/pkp/classes/install/Installer.inc.php
line: 383
```

Rekomendasi:

- Jangka Pendek: Pastikan installer tidak dapat diakses dari lingkungan production.
- Jangka Menengah: Refactor logika installer agar tidak menggunakan `eval()` dan ganti dengan dispatch atau parser statis.
- Jangka Panjang: Larang sink berbahaya seperti `eval()` melalui secure coding standard dan lint rule pada CI/CD.

[VUL-004] Stored XSS via `customHeaders`

Field	Nilai
ID	VUL-004
Nama	Stored XSS via `customHeaders`
OWASP Category	A03:2021 - Injection
CWE	CWE-79

CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:N`
CVSS Base Score	9.0 (Critical; internal alignment)
Tanggal Ditemukan	03/04/2026
Ditemukan Oleh	Manual Code Review Kelompok 3

Deskripsi: Manual review pada `PKPTemplateManager.inc.php` menunjukkan bahwa nilai `customHeaders` dari database diteruskan ke `addHeader()` tanpa sanitasi atau escaping. Ini memungkinkan payload HTML atau JavaScript tersimpan dan dirender kembali ke browser pengguna lain.

Dampak Bisnis: Stored XSS dapat digunakan untuk mencuri cookie sesi, melakukan aksi atas nama user, dan mengambil alih akun Editor atau Administrator.

Langkah Reproduksi:

1. Review source code `PKPTemplateManager.inc.php`.
2. Verifikasi bahwa `customHeaders` dikirim ke `addHeader()` tanpa escaping.
3. Secara konseptual, payload seperti `<script>alert(1)</script>` akan ikut dirender saat halaman dimuat.

Payload / Request:

```
<script>
  alert(1);
</script>
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/manual_code_review.md`
- `../Deliverable Pertemuan 3/Raw-Finding-Table.md`

Response / Output:

```
$customHeaders = $currentContext->getLocalizedData('customHeaders');
if (!empty($customHeaders)) {
    $this->addHeader('customHeaders', $customHeaders);
}
```

Rekomendasi:

- Jangka Pendek: Batasi penggunaan `customHeaders` dan aktifkan CSP dasar.
- Jangka Menengah: Sanitasi `customHeaders` dengan allowlist HTML aman atau fungsi `stripUnsafeHtml()`.
- Jangka Panjang: Standarisasi secure templating dan regression test untuk XSS.

[VUL-005] Unsafe `unserialize()` on Persisted Data

Field	Nilai
ID	VUL-005
Nama	Unsafe `unserialize()` on Persisted Data
OWASP Category	A08:2021 - Software and Data Integrity Failures
CWE	CWE-502
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H`
CVSS Base Score	9.0 (Critical; internal alignment)
Tanggal Ditemukan	03/04/2026
Ditemukan Oleh	Manual Code Review Kelompok 3

Deskripsi: Manual code review pada `DAO.inc.php` menemukan cabang fallback yang memanggil `unserialize($value)` ketika `json_decode()` gagal. Tidak ada `allowed_classes` atau pembatasan objek yang boleh dide-serialisasi.

Dampak Bisnis: Kerentanan ini dapat berkembang menjadi PHP object injection, manipulasi data, atau dalam skenario tertentu code execution melalui gadget chain.

Langkah Reproduksi:

1. Tinjau `DAO.inc.php` pada cabang decoding object/array.
2. Verifikasi bahwa nilai akan di-`unserialize()` tanpa pembatasan class.
3. Analisis potensi pemrosesan serialized object berbahaya.

Payload / Request:

```
$value = unserialize($value);
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/manual_code_review.md`
- `../Deliverable Pertemuan 3/Raw-Finding-Table.md`

Response / Output:

```
if (!is_null($decodedValue)) {
    $value = $decodedValue;
} else {
    $value = unserialize($value);
}
```

Rekomendasi:

- Jangka Pendek: Audit seluruh jalur data yang dapat mengisi nilai persisted object/array.
- Jangka Menengah: Ganti `unserialize()` dengan `json_decode()` atau gunakan `allowed_classes => false`.
- Jangka Panjang: Hapus seluruh legacy compatibility branch yang masih bergantung pada serialized PHP objects.

[VUL-006] Assert() Dynamic Parameter

Field	Nilai
ID	VUL-006
Nama	Assert() Dynamic Parameter
OWASP Category	A03:2021 - Injection
CWE	CWE-94
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H`
CVSS Base Score	8.8 (High)

Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim SAST Kelompok 3

Deskripsi: PHPCS Security Audit menemukan banyak penggunaan `assert()` dengan parameter dinamis di codebase OJS. Pada raw finding final, kasus representatif dirangkum pada `SubmissionHandler.inc.php` line 56.

Dampak Bisnis: Dalam skenario terburuk, attacker dapat menyebabkan evaluasi ekspresi berbahaya, memanipulasi logika program, atau memicu code execution.

Langkah Reproduksi:

1. Jalankan PHPCS Security Audit terhadap codebase.
2. Tinjau warning `Assert eval function assert() detected with dynamic parameter`.
3. Verifikasi instance representatif pada file yang dicatat.

Payload / Request:

```
phpcs --standard=Security --extensions=php ./ojs-src > phpcs_security_output.txt
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan phpcs.png`
- `../Deliverable Pertemuan 3/Phpcs/phpcs_security_output.txt`

Response / Output:

```
Assert eval function assert() detected with dynamic parameter
```

Rekomendasi:

- Jangka Pendek: Review seluruh penggunaan `assert()` pada codebase produksi.
- Jangka Menengah: Ganti `assert()` dengan validasi eksplisit, exception, atau guard clause.
- Jangka Panjang: Terapkan secure coding policy untuk melarang sink evaluasi dinamis di codebase.

[VUL-007] Dynamic File Deletion

Field	Nilai
ID	VUL-007
Nama	Dynamic File Deletion
OWASP Category	A01:2021 - Broken Access Control
CWE	CWE-73
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H`
CVSS Base Score	8.1 (High; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim SAST Kelompok 3

Deskripsi: PHPCS menandai penggunaan fungsi `delete()` dengan parameter dinamis pada `PKPManageFileApiHandler.inc.php`. Tanpa validasi path yang ketat, pola ini dapat berkembang menjadi arbitrary file deletion.

Dampak Bisnis: Penghapusan file yang tidak sah dapat merusak submission, plugin, template, atau file konfigurasi dan memengaruhi ketersediaan layanan jurnal.

Langkah Reproduksi:

1. Jalankan PHPCS Security Audit.
2. Tinjau warning pada handler file management.
3. Konfirmasi bahwa operasi hapus menggunakan parameter dinamis.

Payload / Request:

```
phpcs --standard=Security --extensions=php ./ojs-src > phpcs_security_output.txt
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan phpcs.png`
- `../Deliverable Pertemuan 3/Phpcs/phpcs_security_output.txt`

Response / Output:

```
Filesystem function delete() detected with dynamic parameter
```

Rekomendasi:

- Jangka Pendek: Batasi endpoint pengelolaan file hanya untuk role yang benar-benar membutuhkan.
- Jangka Menengah: Validasi path dengan `realpath()`, whitelist base directory, dan object ownership check.
- Jangka Panjang: Refactor seluruh operasi file menjadi service terpusat dengan policy enforcement konsisten.

[VUL-008] Dynamic File Read (`readfile`)

Field	Nilai
ID	VUL-008
Nama	Dynamic File Read (`readfile`)
OWASP Category	A01:2021 - Broken Access Control
CWE	CWE-73
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
CVSS Base Score	7.5 (High; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim SAST Kelompok 3

Deskripsi: PHPCS menandai `readfile()` dengan parameter dinamis pada `PageHandler.inc.php` line 155. Jika sumber path tidak dibatasi, attacker dapat mengakses file di luar area yang semestinya.

Dampak Bisnis: Potensi dampaknya adalah disclosure terhadap file konfigurasi, template, log, atau dokumen submission yang seharusnya terbatas. Kebocoran `config.inc.php` akan sangat berbahaya karena dapat mengungkap kredensial database.

Langkah Reproduksi:

1. Jalankan PHPCS Security Audit terhadap codebase.
2. Cari instance `readfile()` berbasis variabel.
3. Tinjau `PageHandler.inc.php` sebagai instance representatif.

Payload / Request:

```
phpcs --standard=Security --extensions=php ./ojs-src > phpcs_security_output.txt
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan phpcs.png`
- `../Deliverable Pertemuan 3/Phpcs/phpcs_security_output.txt`

Response / Output:

```
Filesystem function readfile() detected with dynamic parameter
```

Rekomendasi:

- Jangka Pendek: Audit seluruh endpoint yang mengirim file ke client.
- Jangka Menengah: Terapkan whitelist path dan object ownership validation sebelum `readfile()` dipanggil.
- Jangka Panjang: Bangun abstraction layer untuk file access yang memisahkan kontrol akses dari operasi file fisik.

[VUL-009] Variable-based Include/Require

Field	Nilai
ID	VUL-009
Nama	Variable-based Include/Require
OWASP Category	A03:2021 - Injection

CWE	CWE-98
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N`
CVSS Base Score	7.5 (High; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim SAST Kelompok 3

Deskripsi: Semgrep custom rules menemukan 104 instance `include/require` berbasis variabel, dengan salah satu instance representatif berada pada `/var/www/html/ojs/index.php` line 65. Pola ini berisiko apabila variabel sumber tidak divalidasi atau tidak di-whitelist.

Dampak Bisnis: Pemanggilan file yang tidak aman dapat membocorkan source code, memuat file yang tidak semestinya, atau mengubah jalur eksekusi aplikasi.

Langkah Reproduksi:

1. Jalankan Semgrep custom rules pada codebase.
2. Cari rule `php-file-include-variable`.
3. Verifikasi instance representatif pada `index.php` dan file lain yang dicatat.

Payload / Request:

```
semgrep --config custom_rules.yaml --output semgrep_custom.json --json ./ojs-src
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Semgrep/semgrep_custom_results.json`
- `../Deliverable Pertemuan 3/Raw-Finding-Table.md`

Response / Output:

```
check_id: php-file-include-variable
path: /var/www/html/ojs/index.php
line: 65
```

Rekomendasi:

- Jangka Pendek: Inventarisasi seluruh include berbasis variabel yang berada di jalur request.
- Jangka Menengah: Ganti include dinamis dengan mapping statis atau dispatcher berbasis whitelist.
- Jangka Panjang: Tinjau kembali desain loader, plugin system, dan bootstrap process agar tidak bergantung pada include bebas.

[VUL-010] File Upload Without Validation

Field	Nilai
ID	VUL-010
Nama	File Upload Without Validation
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-434
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N`
CVSS Base Score	7.3 (High; internal alignment)
Tanggal Ditemukan	03/04/2026
Ditemukan Oleh	Manual Code Review Kelompok 3

Deskripsi: Manual review pada `FileManager.inc.php` menunjukkan bahwa fungsi inti `uploadFile()` memindahkan file upload tanpa validasi MIME type, ekstensi, atau ukuran file. Validasi sepenuhnya diserahkan ke caller.

Dampak Bisnis: File upload yang tidak tervalidasi dapat digunakan untuk menyimpan file berbahaya, membanjiri storage, atau menanam payload yang nantinya diproses oleh komponen lain.

Langkah Reproduksi:

1. Review fungsi `uploadFile()` pada `FileManager.inc.php`.

2. Verifikasi bahwa file dipindahkan dengan `move_uploaded_file()` tanpa pemeriksaan tipe dan ekstensi pada fungsi inti.
3. Konfirmasi bahwa pengamanan bergantung pada caller.

Payload / Request:

```
move_uploaded_file($_FILES[$fileName]['tmp_name'], $destFileName)
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/manual_code_review.md`
- `../Deliverable Pertemuan 3/Raw-Finding-Table.md`

Response / Output:

```
if (!isset($_FILES[$fileName])) return false;
if (move_uploaded_file($_FILES[$fileName]['tmp_name'], $destFileName))
    return $this->setMode($destFileName, FILE_MODE_MASK);
```

Rekomendasi:

- Jangka Pendek: Batasi role yang dapat mengunggah file dan simpan file upload di luar web root jika memungkinkan.
- Jangka Menengah: Terapkan allowlist MIME type dan ekstensi pada level fungsi inti, bukan hanya caller.
- Jangka Panjang: Bangun upload pipeline terstandar dengan validasi, quarantine, dan review untuk file tertentu.

[VUL-011] Vulnerable jQuery UI v1.12.1

Field	Nilai
ID	VUL-011
Nama	Vulnerable jQuery UI v1.12.1
OWASP Category	A06:2021 - Vulnerable and Outdated Components
CWE	CWE-1395
CVE	CVE-2021-41184

CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N`
CVSS Base Score	6.1 (Medium)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: ZAP mendeteksi penggunaan library `jQuery UI v1.12.1` pada path `/lib/pkp/lib/vendor/components/jqueryui/jquery-ui.min.js?v=3.3.0.8`. Library ini sudah usang dan dikaitkan dengan CVE publik.

Dampak Bisnis: Komponen frontend usang memperbesar attack surface browser-side dan dapat memperkuat dampak XSS atau DOM manipulation.

Langkah Reproduksi:

1. Jalankan ZAP passive scan terhadap aplikasi.
2. Tinjau alert `Vulnerable JS Library`.
3. Verifikasi file library dan versinya pada asset yang disajikan aplikasi.

Payload / Request:

```
docker run -t ghcr.io/zaproxy/zaproxy:stable zap-full-scan.py \
  -t http://10.34.100.180 -r zap_report.html -J zap_report.json
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan OWASP Zap 2.png`
- `../Deliverable Pertemuan 3/Zap/raw_output_zap.html`

Response / Output:

```
Vulnerable JS Library
... jquery-ui.min.js?v=3.3.0.8
```

Rekomendasi:

- Jangka Pendek: Inventarisasi seluruh komponen JS pihak ketiga yang dipakai OJS.
- Jangka Menengah: Upgrade jQuery UI ke versi yang didukung dan kompatibel dengan OJS.
- Jangka Panjang: Terapkan dependency review rutin untuk library client-side.

[VUL-012] Directory Browsing Enabled

Field	Nilai
ID	VUL-012
Nama	Directory Browsing Enabled
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-548
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`
CVSS Base Score	5.3 (Medium)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: ZAP mencatat alert `Directory Browsing` pada 88 direktori, termasuk `/cache/`, `/lib/`, `/plugins/`, dan `/templates/`. Nikto juga memperkuat temuan ini dengan indexing pada beberapa direktori.

Dampak Bisnis: Directory listing memudahkan reconnaissance, enumerasi plugin, identifikasi file cache, dan pemetaan struktur aplikasi.

Langkah Reproduksi:

1. Akses direktori yang terdaftar oleh ZAP atau Nikto.
2. Amati respons `200 OK` beserta daftar isi direktori.
3. Verifikasi bahwa file atau subfolder dapat dilihat tanpa autentikasi.

Payload / Request:

```
curl http://10.34.100.180/cache/
curl http://10.34.100.180/lib/
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan OWASP Zap.png`
- `../Deliverable Pertemuan 3/Zap/raw_output_zap.html`
- `../Deliverable Pertemuan 3/Nikto/raw_output_nikto.txt`

Response / Output:

```
Directory Browsing
count: 88
```

Rekomendasi:

- Jangka Pendek: Nonaktifkan listing direktori dengan `Options -Indexes`.
- Jangka Menengah: Pindahkan file cache, backup, dan artefak non-public ke lokasi yang tidak dapat diakses web.
- Jangka Panjang: Tambahkan pemeriksaan hardening web server ke checklist deployment standar.

[VUL-013] Content Security Policy (CSP) Header Not Set

Field	Nilai
ID	VUL-013
Nama	Content Security Policy (CSP) Header Not Set
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-693
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N`
CVSS Base Score	4.7 (Medium; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: ZAP mendeteksi 573 respons tanpa header `Content-Security-Policy`. Tanpa CSP, browser tidak memiliki batasan eksplisit atas sumber script, style, frame, dan resource lain yang boleh dimuat.

Dampak Bisnis: Ketiadaan CSP memperlemah pertahanan browser dan memperbesar dampak temuan XSS maupun injeksi resource pihak ketiga.

Langkah Reproduksi:

1. Jalankan ZAP passive scan.
2. Periksa daftar alert untuk `Content Security Policy (CSP) Header Not Set`.
3. Verifikasi header respons menggunakan `curl -I`.

Payload / Request:

```
curl -I http://10.34.100.180/
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan OWASP Zap.png`
- `../Deliverable Pertemuan 3/Zap/raw_output_zap.html`

Response / Output:

```
Content Security Policy (CSP) Header Not Set
count: 573
```

Rekomendasi:

- Jangka Pendek: Terapkan CSP dasar dengan `default-src 'self'`.
- Jangka Menengah: Perketat directive `script-src`, `style-src`, `img-src`, dan `frame-ancestors`.
- Jangka Panjang: Standarkan kebijakan CSP untuk seluruh deployment OJS dan tinjau kembali saat plugin baru ditambahkan.

[VUL-014] Missing Anti-clickjacking Header

Field	Nilai
ID	VUL-014
Nama	Missing Anti-clickjacking Header
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-693
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N`
CVSS Base Score	4.7 (Medium; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: ZAP mendeteksi 122 respons tanpa proteksi anti-clickjacking, artinya halaman dapat di-embed ke dalam iframe dari origin lain.

Dampak Bisnis: Clickjacking dapat digunakan untuk menipu pengguna agar mengklik elemen yang tidak mereka sadari, termasuk tombol login, submit, atau aksi konfigurasi.

Langkah Reproduksi:

1. Jalankan ZAP passive scan.
2. Periksa alert `Missing Anti-clickjacking Header`.
3. Konfirmasi bahwa `X-Frame-Options` atau `frame-ancestors` tidak ada pada respons.

Payload / Request:

```
curl -I http://10.34.100.180/
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan OWASP Zap.png`
- `../Deliverable Pertemuan 3/Zap/raw_output_zap.html`

Response / Output:

```
Missing Anti-clickjacking Header
count: 122
```

Rekomendasi:

- Jangka Pendek: Tambahkan `X-Frame-Options: SAMEORIGIN`.
- Jangka Menengah: Lengkapi dengan directive CSP `frame-ancestors 'self'`.
- Jangka Panjang: Uji seluruh route sensitif agar tidak dapat di-embed lintas domain.

[VUL-015] Application Error Disclosure

Field	Nilai
ID	VUL-015
Nama	Application Error Disclosure
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-209
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N`
CVSS Base Score	4.3 (Medium; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: ZAP mencatat `Application Error Disclosure` pada sejumlah file compiled template di `/cache/t_compile/` dan endpoint lain. Pesan error yang bocor membantu attacker memahami struktur file internal dan area aplikasi yang gagal menangani exception secara aman.

Dampak Bisnis: Informasi error mempermudah reconnaissance, mempercepat exploit development, dan mengurangi effort attacker untuk memetakan aplikasi.

Langkah Reproduksi:

1. Jalankan ZAP terhadap aplikasi.
2. Tinjau alert `Application Error Disclosure`.
3. Akses salah satu path yang disebutkan di laporan untuk melihat detail kebocoran error.

Payload / Request:

```
curl http://10.34.100.180/cache/t_compile/
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan OWASP Zap 2.png`
- `../Deliverable Pertemuan 3/Zap/raw_output_zap.html`

Response / Output:

```
Application Error Disclosure
```

Rekomendasi:

- Jangka Pendek: Matikan debug output di production dan batasi akses ke direktori cache compiled.
- Jangka Menengah: Gunakan custom error page dan logging server-side yang tidak mengekspos detail ke client.
- Jangka Panjang: Tambahkan negative testing pada deployment checklist untuk memastikan error yang tampil ke pengguna selalu generik.

[VUL-016] Missing Strict-Transport-Security Header

Field	Nilai
ID	VUL-016
Nama	Missing Strict-Transport-Security (HSTS)
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-319

CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N`
CVSS Base Score	4.3 (Low; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: Nikto melaporkan bahwa header `strict-transport-security` tidak ada pada response root aplikasi. Tanpa HSTS, browser tidak dipaksa untuk selalu menggunakan HTTPS pada koneksi berikutnya.

Dampak Bisnis: Absennya HSTS meningkatkan risiko downgrade attack dan skenario man-in-the-middle bila trafik HTTPS belum diterapkan konsisten.

Langkah Reproduksi:

1. Jalankan Nikto terhadap target.
2. Periksa alert missing `strict-transport-security`.
3. Konfirmasi dengan `curl -I`.

Payload / Request:

```
nikto -h http://10.34.100.180 -o raw_output_nikto.txt -Format txt
curl -I http://10.34.100.180/
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan Nikto.png`
- `../Deliverable Pertemuan 3/Nikto/raw_output_nikto.txt`

Response / Output:

```
Suggested security header missing: strict-transport-security
```

Rekomendasi:

- Jangka Pendek: Aktifkan HTTPS secara penuh terlebih dahulu.
- Jangka Menengah: Tambahkan `Strict-Transport-Security: max-age=31536000; includeSubDomains` setelah validasi HTTPS selesai.
- Jangka Panjang: Lakukan review berkala pada seluruh security headers browser-facing.

[VUL-017] Missing X-Content-Type-Options Header

Field	Nilai
ID	VUL-017
Nama	Missing X-Content-Type-Options
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-693
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N`
CVSS Base Score	4.3 (Low; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: Nikto melaporkan bahwa header `x-content-type-options` tidak ada. Tanpa `nosniff`, browser dapat melakukan MIME sniffing dan menginterpretasikan resource dengan tipe yang tidak semestinya.

Dampak Bisnis: Header ini membantu memperkecil risiko beberapa skenario content confusion, file handling error, dan injeksi konten yang bergantung pada interpretasi browser.

Langkah Reproduksi:

1. Jalankan Nikto atau `curl -I`.
2. Verifikasi bahwa `X-Content-Type-Options` tidak dikirim server.

Payload / Request:

```
nikto -h http://10.34.100.180 -o raw_output_nikto.txt -Format txt
curl -I http://10.34.100.180/
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan Nikto.png`
- `../Deliverable Pertemuan 3/Nikto/raw_output_nikto.txt`

Response / Output:

```
Suggested security header missing: x-content-type-options
```

Rekomendasi:

- Jangka Pendek: Tambahkan header `X-Content-Type-Options: nosniff`.
- Jangka Menengah: Review tipe konten dan kebijakan file serving pada route yang mengirim file.
- Jangka Panjang: Masukkan header ini ke baseline config semua virtual host aplikasi web.

[VUL-018] phpinfo() Exposure

Field	Nilai
ID	VUL-018
Nama	phpinfo() Exposure
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-200
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N`
CVSS Base Score	4.3 (Medium; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim SAST Kelompok 3

Deskripsi: Semgrep ruleset `p/php` dan `p/owasp-top-ten` sama-sama menandai pemanggilan `phpinfo()` pada `AdminHandler.inc.php` line 375. Fungsi ini dapat mengungkap konfigurasi PHP, modul aktif, environment variable, serta detail server bila tersedia pada production.

Dampak Bisnis: Paparan informasi teknis detail memudahkan fingerprinting dan pemetaan exploit yang kompatibel.

Langkah Reproduksi:

1. Jalankan Semgrep ruleset `p/php` dan `p/owasp-top-ten`.
2. Cari rule `php.lang.security.phpinfo-use.phpinfo-use`.
3. Verifikasi lokasi pemanggilan `phpinfo()`.

Payload / Request:

```
semgrep --config p/php --json ./ojs-src
semgrep --config p/owasp-top-ten --json ./ojs-src
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Semgrep/semgrep_php_results.json`
- `../Deliverable Pertemuan 3/Semgrep/semgrep_owasp_results.json`

Response / Output:

```
The 'phpinfo' function may reveal sensitive information about your environment.
path: /var/www/html/ojs/lib/pkp/pages/admin/AdminHandler.inc.php
```

Rekomendasi:

- Jangka Pendek: Pastikan fungsi atau route diagnostik tidak dapat diakses pada production.
- Jangka Menengah: Hapus pemanggilan `phpinfo()` dari jalur production atau batasi hanya untuk mode debug internal.
- Jangka Panjang: Sediakan halaman health check yang aman dan tidak mengekspos konfigurasi detail.

[VUL-019] Possible CSRF on Search Form

Field	Nilai
ID	VUL-019
Nama	Possible CSRF on Search Form

OWASP Category	A01:2021 - Broken Access Control
CWE	CWE-352
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N`
CVSS Base Score	4.3 (Low; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: Nmap script `http-csrf` menandai form pencarian pada `http://10.34.100.180/index.php/halo/search` sebagai `possible CSRF vulnerabilities`. Temuan ini bersifat indikatif dan belum tervalidasi penuh sebagai exploit path yang berbahaya.

Dampak Bisnis: Untuk form pencarian, dampaknya relatif rendah dibanding endpoint perubahan state, tetapi finding ini menunjukkan perlunya verifikasi menyeluruh pada proteksi CSRF di form publik dan endpoint lain yang memproses aksi pengguna.

Langkah Reproduksi:

1. Jalankan Nmap dengan skrip `http-csrf`.
2. Amati form yang ditandai pada path pencarian.
3. Lakukan verifikasi manual lanjutan bila form tersebut mengubah state atau memicu action sensitif.

Payload / Request:

```
nmap -sV --script vuln 10.34.100.180
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan Nmap.png`
- `../Deliverable Pertemuan 3/Nmap/nmap_vuln.txt`

Response / Output:

```
Found the following possible CSRF vulnerabilities:
Path: http://10.34.100.180:80/index.php/halo/search
Form id: query
```

Rekomendasi:

- Jangka Pendek: Verifikasi secara manual apakah form pencarian benar-benar membutuhkan CSRF token.
- Jangka Menengah: Terapkan token CSRF pada endpoint yang memproses perubahan state atau permintaan sensitif.
- Jangka Panjang: Standarisasi perlindungan CSRF untuk seluruh endpoint form-based dan API yang menerima session cookie.

[VUL-020] Missing Referrer-Policy Header

Field	Nilai
ID	VUL-020
Nama	Missing Referrer-Policy Header
OWASP Category	A05:2021 - Security Misconfiguration
CWE	CWE-693
CVE	-
CVSS v3.1 Vector	`CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N`
CVSS Base Score	3.2 (Low; internal alignment)
Tanggal Ditemukan	02/04/2026
Ditemukan Oleh	Tim DAST Kelompok 3

Deskripsi: Nikto melaporkan bahwa header `Referrer-Policy` tidak ada pada response root aplikasi. Tanpa kebijakan ini, browser dapat mengirim URL asal secara lebih luas daripada yang diinginkan.

Dampak Bisnis: Risiko utamanya adalah kebocoran informasi konteks URL yang tidak perlu ke pihak ketiga, terutama bila nantinya ada parameter atau path internal yang sensitif.

Langkah Reproduksi:

1. Jalankan Nikto terhadap target.
2. Konfirmasi bahwa `referrer-policy` tidak dikirim server.

Payload / Request:

```
nikto -h http://10.34.100.180 -o raw_output_nikto.txt -Format txt
curl -I http://10.34.100.180/
```

Bukti (Screenshot):

- `../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan Nikto.png`
- `../Deliverable Pertemuan 3/Nikto/raw_output_nikto.txt`

Response / Output:

```
Suggested security header missing: referrer-policy
```

Rekomendasi:

- Jangka Pendek: Tambahkan `Referrer-Policy: strict-origin-when-cross-origin`.
- Jangka Menengah: Review apakah ada route yang membawa informasi sensitif di URL.
- Jangka Panjang: Jadikan review browser security headers sebagai bagian dari hardening checklist.

---

5. Risk Register & Summary

5.1 Distribusi Risiko

Tingkat Risiko	Jumlah Temuan	ID
Critical	5	VUL-001, VUL-003, VUL-004, VUL-005, VUL-006
High	5	VUL-002, VUL-007, VUL-008, VUL-009, VUL-010

Medium	6	VUL-011, VUL-012, VUL-013, VUL-014, VUL-015, VUL-018
Low	4	VUL-016, VUL-017, VUL-019, VUL-020

5.2 Risk Register Final

ID	Kerentanan	OWASP	CVSS	Rating	Likelihood	Biz Impact	Risk	Prioritas
VUL-001	Apache HTTP RCE (CVE-2024-38476)	A06	9.8	Critical	4	5	Critical	1
VUL-003	Eval Injection (Installer)	A03	9.8	Critical	4	5	Critical	2
VUL-004	Stored XSS via `customHeaders`	A03	9.0	Critical	3	5	Critical	3
VUL-005	Unsafe `unserialize()` (DAO)	A08	9.0	Critical	3	5	Critical	4
VUL-006	Assert() Dynamic Parameter	A03	8.8	High	4	5	Critical	5
VUL-007	Dynamic File Deletion	A01	8.1	High	4	4	High	6
VUL-002	OpenSSH RegreSSHion (CVE-2024-6387)	A06	8.1	High	2	5	High	7
VUL-008	Dynamic File Read (`readfile`)	A01	7.5	High	4	4	High	8
VUL-009	Variable-based Include/Require	A03	7.5	High	3	4	High	9
VUL-010	File Upload Without Validation	A05	7.3	High	2	5	High	10

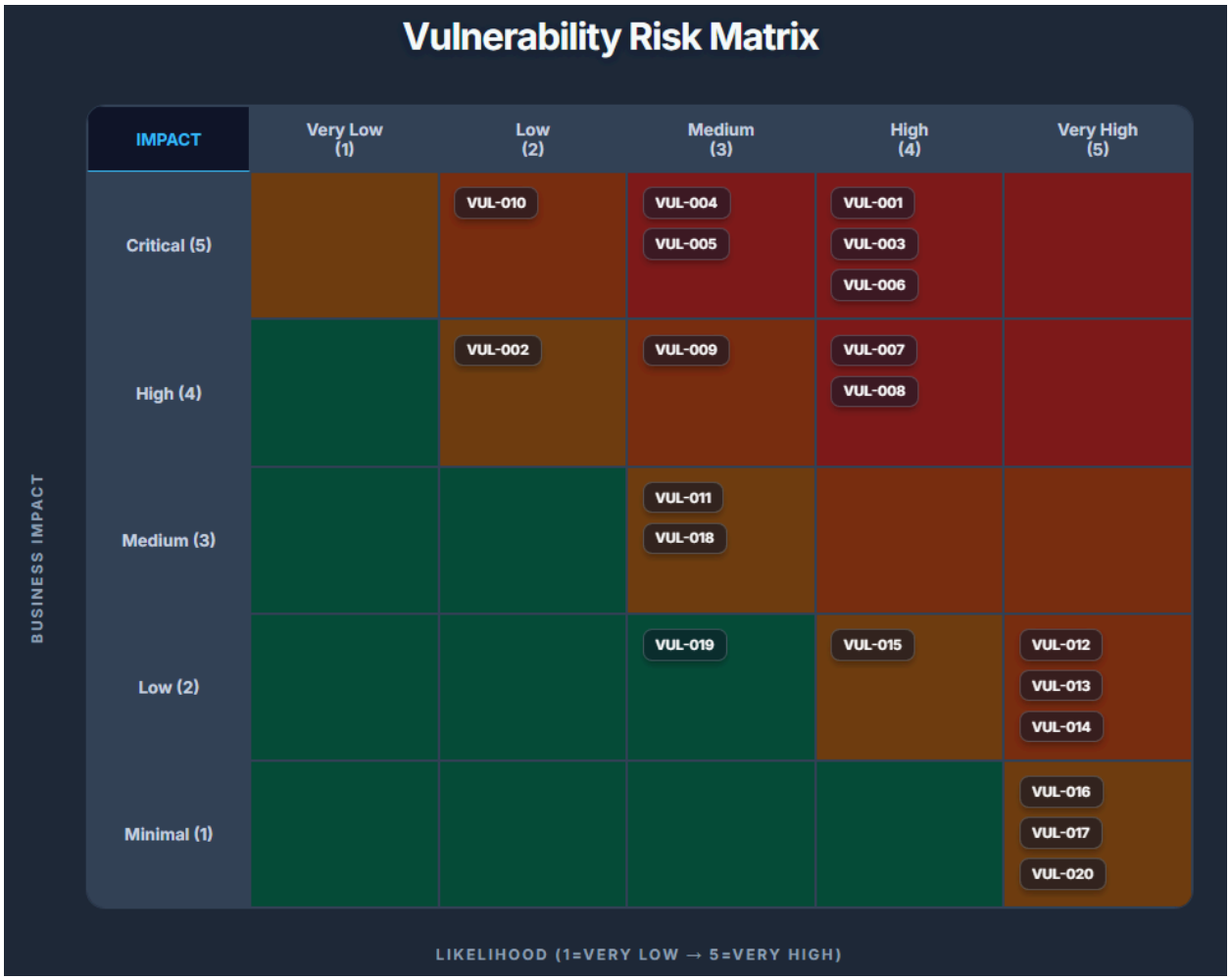
VUL-011	Vulnerable jQuery UI v1.12.1	A06	6.1	Medium	3	3	Medium	11
VUL-012	Directory Browsing Enabled	A05	5.3	Medium	5	2	Medium	12
VUL-013	CSP Header Not Set	A05	4.7	Medium	5	2	Medium	13
VUL-014	Missing Anti-clickjacking Header	A05	4.7	Medium	5	2	Medium	14
VUL-018	phpinfo() Exposure	A05	4.3	Medium	3	3	Medium	15
VUL-015	Application Error Disclosure	A05	4.3	Medium	4	2	Medium	16
VUL-016	Missing HSTS Header	A05	4.3	Medium	5	1	Low	17
VUL-017	Missing X-Content-Type-Options	A05	4.3	Medium	5	1	Low	18
VUL-019	Possible CSRF on Search Form	A01	4.3	Medium	3	2	Low	19
VUL-020	Missing Referrer-Policy Header	A05	3.2	Low	5	1	Low	20

5.3 Ringkasan Prioritas

Prioritas	Fokus	Temuan
P1	Hotfix untuk mencegah compromise host dan code execution	VUL-001, VUL-003, VUL-004, VUL-005, VUL-006
P2	Hardening akses file, include path, dan komponen sistem	VUL-002, VUL-007, VUL-008, VUL-009, VUL-010

P3	Perbaikan konfigurasi browser-facing dan hygiene komponen	VUL-011, VUL-012, VUL-013, VUL-014, VUL-015, VUL-016, VUL-017, VUL-018, VUL-020
P4	Verifikasi proteksi preventif residual risk	VUL-019

Risk Matrix



6. Rekomendasi Mitigasi

6.1 Jangka Pendek (0-7 hari)

No	Tindakan	Target Kerentanan	Penanggung Jawab
1	Upgrade Apache HTTP Server dan OpenSSH ke rilis vendor-supported yang sudah patched	VUL-001, VUL-002	SysAdmin
2	Nonaktifkan installer atau jalur instalasi ulang pada production	VUL-003	SysAdmin / App Admin
3	Nonaktifkan atau batasi `customHeaders`, lalu aktifkan CSP dasar	VUL-004, VUL-013	App Admin
4	Audit penggunaan `assert()`, `eval()`, dan `unserialize()` pada codebase	VUL-003, VUL-005, VUL-006	Developer
5	Nonaktifkan directory listing dengan `Options -Indexes`	VUL-012	SysAdmin
6	Terapkan header `X-Frame-Options`, `X-Content-Type-Options`, dan `Referrer-Policy`	VUL-014, VUL-017, VUL-020	SysAdmin
7	Matikan debug output dan batasi akses ke cache compiled template	VUL-015	SysAdmin / Developer
8	Pastikan route atau fungsi `phpinfo()` tidak dapat diakses di production	VUL-018	Developer

6.2 Jangka Menengah (7-30 hari)

No	Tindakan	Target Kerentanan
1	Refactor sink berbahaya (`eval`, `assert`, `include/require` dinamis) menjadi logic statis atau whitelist	VUL-003, VUL-006, VUL-009
2	Ganti `unserialize()` dengan format data aman, atau pakai `allowed_classes => false`	VUL-005
3	Terapkan kontrol akses berbasis ID file dan whitelist `realpath()` untuk operasi file	VUL-007, VUL-008
4	Terapkan validasi MIME, ekstensi, ukuran, dan lokasi simpan file pada fungsi inti upload	VUL-010
5	Upgrade jQuery UI dan review dependensi frontend lain	VUL-011
6	Aktifkan HTTPS penuh dan HSTS setelah validasi sertifikat selesai	VUL-016
7	Tambahkan CSP produksi yang lebih ketat dengan `frame-ancestors`, `script-src`, dan `img-src` yang sesuai	VUL-004, VUL-013, VUL-014
8	Verifikasi kebutuhan token CSRF pada seluruh form dan endpoint session-based	VUL-019

6.3 Jangka Panjang (30-90 hari)

No	Tindakan	Tujuan
1	Implementasi DevSecOps pipeline untuk SAST, dependency review, dan baseline DAST	Deteksi dini kerentanan sejak tahap development

2	Kebijakan patch management untuk middleware, OJS, plugin, dan library frontend	Menurunkan risiko komponen usang berulang
3	Secure coding guideline untuk output escaping, file handling, serialization, dan sink evaluasi dinamis	Menurunkan risiko injection dan file abuse
4	Penetration test berkala dan patch verification pasca remediasi	Memastikan efektivitas perbaikan
5	Pelatihan keamanan bagi pengelola jurnal dan admin sistem	Mengurangi salah konfigurasi dan memperkuat respons operasional

6.4 Contoh Konfigurasi Hardening

```
Header always set X-Content-Type-Options "nosniff"
Header always set X-Frame-Options "SAMEORIGIN"
Header always set Referrer-Policy "strict-origin-when-cross-origin"
Header always set Content-Security-Policy "default-src 'self'; frame-ancestors 'self'; object-src 'none'; base-uri 'self'"
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"

ServerTokens Prod
ServerSignature Off
Options -Indexes
```

```
session.cookie_httponly = On
session.cookie_secure = On
session.cookie_samesite = Lax
```

---

7. Patch Verification

Patch verification belum dilakukan pada artefak repository ini, sehingga seluruh finding pada risk register final masih berstatus Open - patch verification diperlukan. Section ini disiapkan sebagai panduan verifikasi setelah tim implementasi selesai menerapkan perbaikan.

No	Temuan	Metode Verifikasi	Bukti yang Diperlukan
1	VUL-001 Apache RCE	Jalankan ulang service/version scan	Output Nmap menunjukkan versi patched
2	VUL-002 OpenSSH RegreSSHion	Jalankan ulang service/version scan	Output Nmap menunjukkan versi patched
3	VUL-003 Eval Injection	Review source code dan re-run Semgrep	Rule `php-eval-injection` tidak lagi match
4	VUL-004 Stored XSS	Uji ulang payload yang sama	Payload tidak tereksekusi; response ter-sanitasi

5	VUL-005 Unsafe `unserialize()`	Review patch dan unit test	Tidak ada `unserialize()` tanpa `allowed_classes`
6	VUL-006 Assert dynamic	Re-run PHPCS security audit	Warning `assert()` dinamis hilang atau terdokumentasi aman
7	VUL-007 File deletion	Test path invalid dan otorisasi	File di luar whitelist tidak dapat dihapus
8	VUL-008 File read	Test akses file sensitif	`config.inc.php` dan file sensitif tidak dapat diakses
9	VUL-009 Variable include	Re-run Semgrep	Rule include berbasis variabel turun atau hilang
10	VUL-010 File upload	Upload file dengan ekstensi/MIME palsu	Request ditolak
11	VUL-012 Directory browsing	Akses `/cache/`, `/lib/`, `/plugins/`	Response `403` atau redirect aman
12	VUL-013 CSP	`curl -I` atau browser devtools	Header CSP muncul konsisten
13	VUL-014 Anti-clickjacking	`curl -I` atau browser devtools	`X-Frame-Options` atau `frame-ancestors` aktif
14	VUL-015 Error disclosure	Uji endpoint yang dulu bocor	Error generik tanpa detail internal
15	VUL-016/VUL-017/VUL-020	`curl -I` pada root aplikasi	HSTS, `nosniff`, dan `Referrer-Policy` aktif
16	VUL-018 phpinfo	Review source code dan route admin	Fungsi diagnostik tidak tersedia di production
17	VUL-019 Possible CSRF	Uji manual form dan endpoint terkait	Token CSRF atau kontrol kompensasi tersedia

8. Kesimpulan

1. Kondisi keamanan OJS 3.3.0-8 pada lingkungan uji menunjukkan kombinasi masalah di level host, aplikasi, dan konfigurasi browser-facing, sehingga belum ideal untuk operasional produksi tanpa remediation tambahan.
2. Risiko paling kritis berada pada dua area: komponen middleware yang usang pada perimeter host dan pola kode berbahaya yang dapat berkembang menjadi code execution, arbitrary file access, atau persistent XSS.
3. Total 10 dari 20 finding berada pada level Critical dan High, sehingga perbaikan tidak dapat ditunda sebagai backlog biasa; tim perlu menjalankan hotfix dan hardening terarah dalam 7-30 hari pertama.
4. Pengujian SQLMap tidak menemukan SQL injection tervalidasi pada parameter yang diuji, tetapi hasil ini tidak menurunkan urgensi temuan lain yang justru lebih berbahaya dalam konteks sistem yang diuji.
5. Langkah jangka panjang yang paling penting adalah membangun proses patch management dan DevSecOps pipeline yang memadukan SAST, DAST, dependency review, dan patch verification setelah remediasi.

---

9. Lampiran

Lampiran A - Raw Output Nikto

- File: `../Deliverable Pertemuan 3/Nikto/raw_output_nikto.txt`
- Ringkasan utama: Apache `2.4.58`, missing `strict-transport-security`, `x-content-type-options`, `referrer-policy`, serta directory indexing.
- Screenshot:

```
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          10.34.100.180
+ Target Hostname:    10.34.100.180
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-04-02 13:16:58 (GMT7)
---------------------------------------------------------------------------
+ Server: Apache/2.4.58 (Ubuntu)
+ [95] /: Cookie OJSSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [750500] /docs/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [750500] /cache/: Directory indexing found.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [600050] Apache/2.4.58 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-P
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
```

Lampiran B - Raw Output ZAP

- File HTML: `../Deliverable Pertemuan 3/Zap/raw_output_zap.html`
- File modern report: `../Deliverable Pertemuan 3/Zap/zap_report_modern.html`
- File PDF: `../Deliverable Pertemuan 3/Zap/zap_report.pdf`
- Screenshot:

ZAP by Checkmarx Owasp ZAP

used for DevSecOps OJS

Site: http://10.34.100.180

Generated on Thu, 2 Apr 2026 10:02:36

ZAP Version: 2.16.1

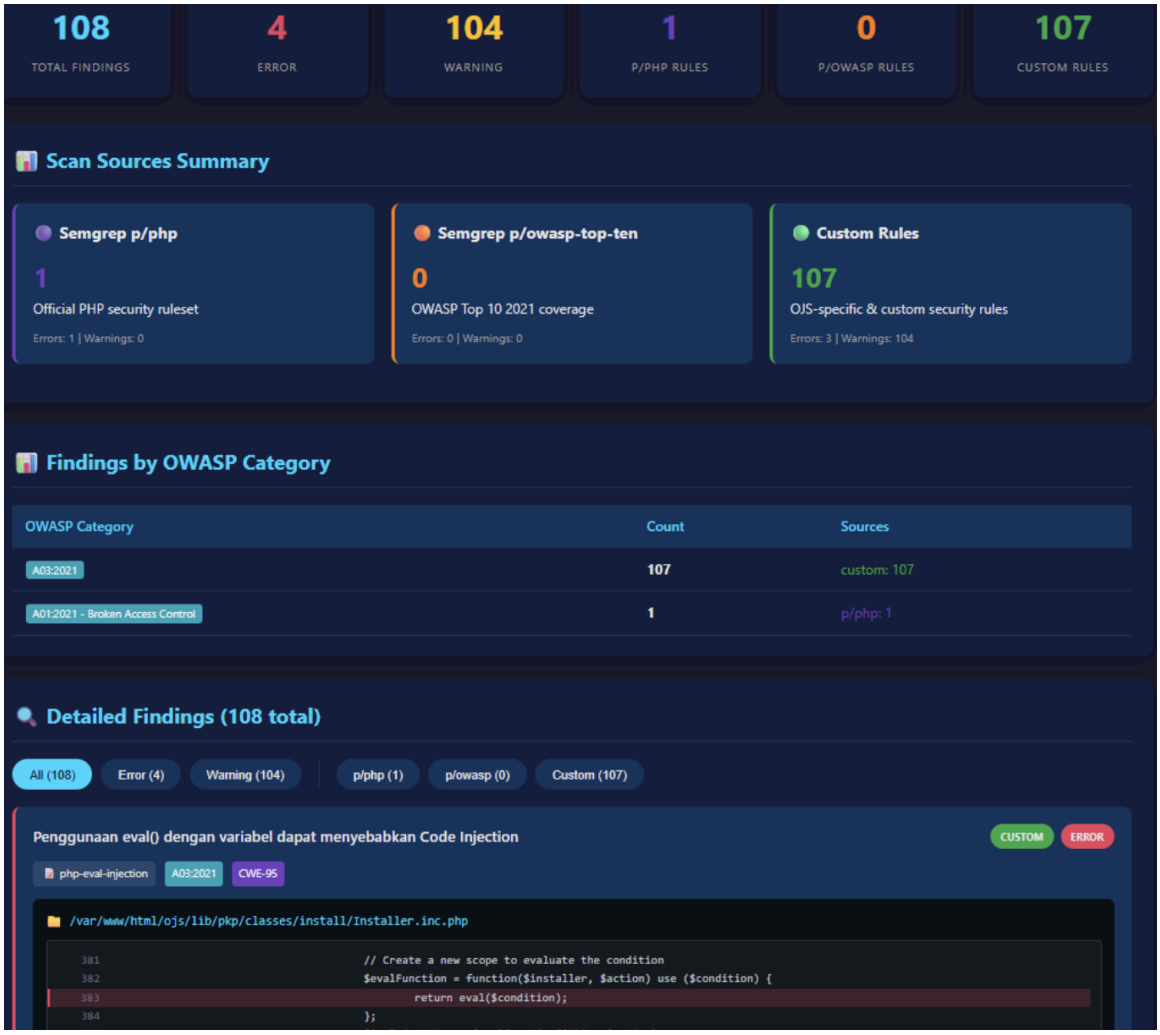
ZAP by Checkmarx

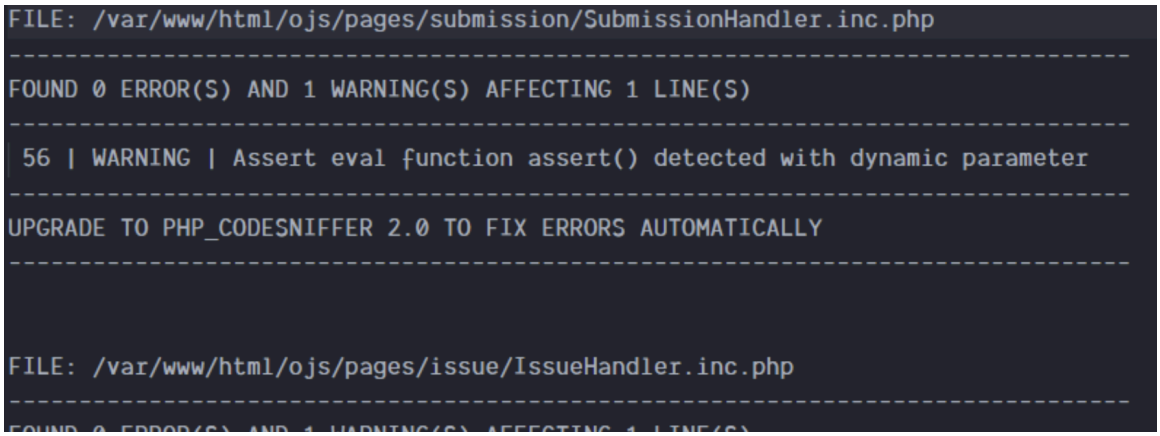
Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	5
Low	6
Informational	15

Lampiran C - Raw Output Semgrep dan PHPCS

- `../Deliverable Pertemuan 3/Semgrep/semgrep_custom_results.json`
- `../Deliverable Pertemuan 3/Semgrep/semgrep_php_results.json`
- `../Deliverable Pertemuan 3/Semgrep/semgrep_owasp_results.json`
- `../Deliverable Pertemuan 3/Phpcs/phpcs_security_output.txt`
- Screenshot:

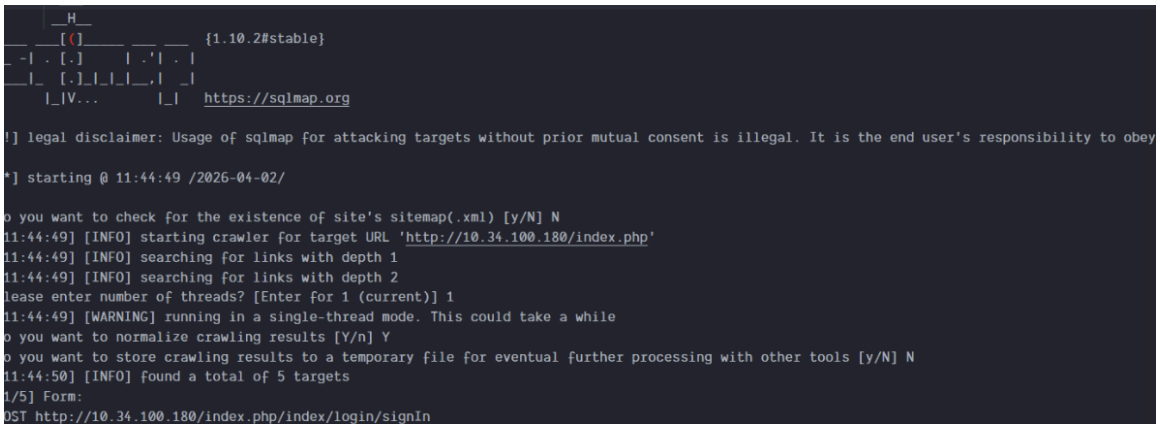


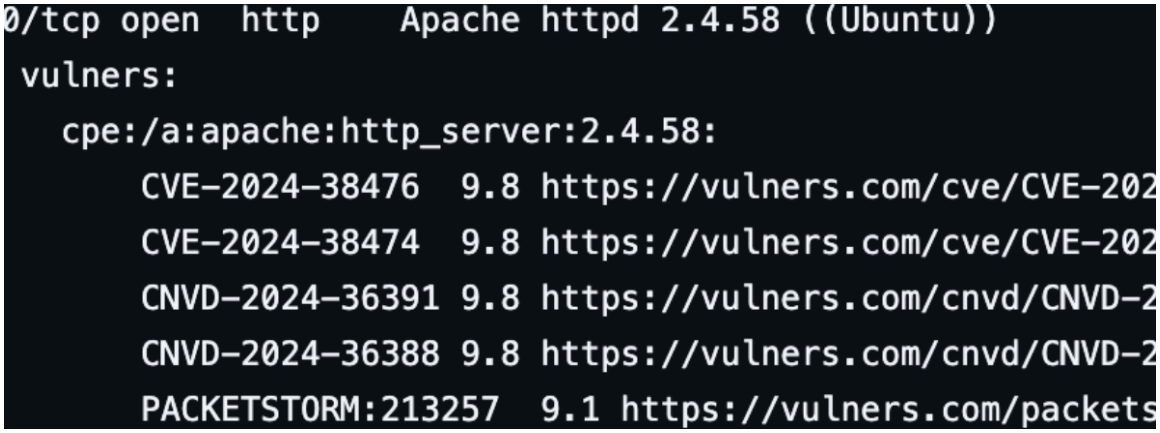


Lampiran D - Raw Output Nmap dan SQLMap

- `../Deliverable Pertemuan 3/Nmap/nmap_vuln.txt`
- `../Deliverable Pertemuan 3/SQLMap/Crawl/crawl_sqlmap.txt`

- `../Deliverable Pertemuan 3/SQLMap/Login and Search/login_sqlmap.txt`
- `../Deliverable Pertemuan 3/SQLMap/Login and Search/search_sqlmap.txt`
- Screenshot:





Lampiran E - Screenshot Bukti

No	Artefak Screenshot	Keterangan
1	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan Nmap.png`	Bukti service version dan CVE mapping
2	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan Nikto.png`	Bukti header dan indexing findings
3	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan OWASP Zap.png`	Bukti alert ZAP
4	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan OWASP Zap 2.png`	Bukti alert ZAP tambahan

5	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan phpcs.png`	Bukti hotspot PHPCS
6	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan SqlMap-Crawl.png`	Bukti eksekusi SQLMap
7	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan SqlMap-Request 1.png`	Bukti SQLMap request-based test
8	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan SqlMap-Request 2.png`	Bukti SQLMap request-based test
9	`../Deliverable Pertemuan 3/Screenshot Bukti Eksploitasi/Hasil Temuan SqlMap-Search.png`	Bukti SQLMap search test

Lampiran F - Daftar Anggota Tim

Nama	NIM	Peran	Kontribusi Utama
Joshua Washington Hutasoit	235150207111037	Security Engineer (DAST)	Menjalankan DAST, enumerasi service, dan konsolidasi bukti scanning
Brahmantio Jati Pambudi	235150201111028	Documentation & Reporting	Menyusun dokumentasi, narasi laporan, dan finalisasi deliverable
Malvinshah Haris Athala	235150207111042	Security Engineer (DAST)	Menjalankan scanning DAST dan validasi hasil tool
Steven Anthony	235150201111035	Security Engineer (DAST)	Menjalankan scanning DAST dan review output teknis
Darvesh Aziz Mawla	235150201111036	Security Engineer (SAST)	Menjalankan SAST dan analisis hotspot source code

Sandhika Rizqi Ramadhan	235150200111019	Project Lead	Koordinasi scope, prioritas temuan, dan integrasi hasil
Rhesa Tsaqif Adyatma	235150200111020	Documentation & Reporting	Penyusunan laporan final, penggabungan artefak, dan presentasi
Mohamad Robi Alwan	235150200111025	Security Engineer (SAST)	Menjalankan SAST, manual review, dan pemetaan OWASP/CVSS

Lampiran G - Referensi

1. OWASP Top 10 2021. https://owasp.org/Top10/
2. NIST NVD CVSS Calculator. https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator
3. PKP OJS Security Advisories. https://pkp.sfu.ca/security-advisories/
4. NVD - CVE-2024-38476. https://nvd.nist.gov/vuln/detail/CVE-2024-38476
5. NVD - CVE-2024-6387. https://nvd.nist.gov/vuln/detail/CVE-2024-6387
6. NVD - CVE-2021-41184. https://nvd.nist.gov/vuln/detail/CVE-2021-41184
7. OWASP XSS Prevention Cheat Sheet. https://owasp.org/www-community/xss-prevention
8. OWASP File Upload Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html
9. OWASP CSRF Prevention Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
10. OWASP Secure Headers Project. https://owasp.org/www-project-secure-headers/
11. Apache HTTP Server Security Reports. https://httpd.apache.org/security_report.html
12. OpenSSH. https://www.openssh.com/
13. Nikto. https://cirt.net/Nikto2
14. OWASP ZAP. https://www.zaproxy.org/docs/
15. SQLMap. https://sqlmap.org/
16. Semgrep. https://semgrep.dev/
17. phpcs-security-audit. https://github.com/pheromone/phpcs-security-audit

Kerahasiaan Dokumen

Laporan ini bersifat rahasia dan disusun hanya untuk keperluan akademis mata kuliah DevSecOps. Dokumen tidak untuk didistribusikan ke pihak luar tanpa izin tertulis dari dosen pengampu.